

Layer 4: Ensuring sustainable security practice with the right tools and frameworks

At the innermost circle lie tools and frameworks. These support secure system development and maintenance, and include everything from automation tools and learning paths to the frameworks and assessments necessary to implement security effectively.

Who are the stakeholders?

The stakeholders here are the development teams who face and overcome the everyday challenges of software implementation.

What are the objectives?

The objectives here are actionable resources like secure pipelines, coding guides, toolkits, and checklists. Additionally, we want to create metrics for the tools and frameworks too. These should include automation coverage statistics and the percentage of false positives; they should be refined regularly to ensure they remain up-to-date and relevant.

What are the intended outcomes?

These tools and frameworks help operationalise the security vision, building consistency in the software development process. They should enable continuous improvement by staying on top of evolving trends and providing insights from the organisational grassroots to the other layers — while remaining true to core values and principles.

Mapping the economics of security

Before concluding, it is pivotal to recognise the delicate balance between security and the economic foundations governing organisational decision-making. This model highlights a paradigm shift — from perceiving security solely as a cost to recognising its potential as an investment, and

allows for adaptable economic adjustments.

Costs, investments and trade-offs: Every security decision has an associated economic cost. For example, consider Layer 1, where the vision for organisational security is formulated. Setting a vision involves defining core security principles. But what's the cost of not incorporating feedback from grassroots levels, as highlighted in Layer 4? Perhaps it is the expense incurred when remedying a security breach that could have been avoided with a tool flagged by a grassroots team. Using the economics of security, such costs can be quantified, guiding organisations in understanding the trade-offs between immediate costs and potential future savings.

Investment valuation:

Allocating resources to ensure security is an investment, not merely an expense. Consider Layer 2, which delves into the security journey of business units. If a particular unit is at a higher risk due to the nature of its data, would the return on investment (ROI) not justify a greater security allocation here? The economics of security helps frame such decisions by projecting the value of proactive security measures against potential losses.

Economic metrics for strategy

refinement: At Layer 3, we discuss bridging strategy and execution. Here, metrics such as vulnerability density can be associated with direct and indirect economic costs, such as system downtime or loss of customer trust. By associating each metric with its economic consequence, organisations can prioritise areas that offer the most value in terms of risk mitigation.

Operational efficiency with tools and frameworks: In Layer 4, the tools and frameworks are the workhorses that operationalise security vision. The efficiency of these tools can be measured in economic terms too. For instance, an automation tool that reduces manual hours and error rates has a direct ROI, while a framework that prevents a major security breach safeguards potential revenue loss.

Embracing the economics of security provides organisations with a tangible, quantifiable method to understand, measure, and enhance their security posture. It allows for better resource allocation, clearer understanding of ROI on security investments, and most importantly, a more secure and economically viable future.

No organisation is a monolith. Yet organisations still often manage security centrally, removing accountability from several stakeholders and leaving the security team understaffed. This opens them up to risks and vulnerabilities that cannot, ironically, be resolved by centralised decision-makers.

To change this, it's imperative to approach security as a layered problem. The 'stakeholder driven security perspectives' framework offers a practical and simplified approach to decentralising security accountability and guidance. It ensures security objectives, actions, and principles align with the realities of the organisation's people, processes, technology, and culture, as well as the evolving demands of the industry and domain. It helps weave security into the organisation's DNA, building preparedness for threats in an ever-changing threat landscape. **END** 

 By: Harinee Muralinath

The author is chief information security officer at Thoughtworks (India & Middle East), open-source contributor and maintainer.